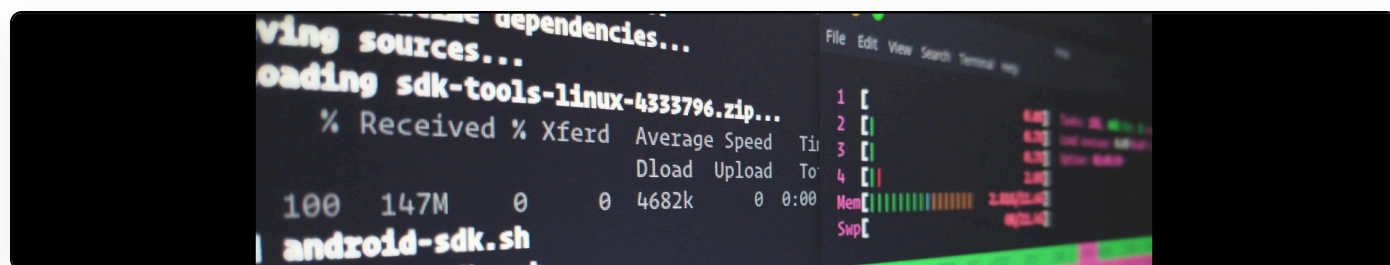


httpOnly Cookie Detection

Cite as: Martin Paul Eve, "httpOnly Cookie Detection", *eve.gd: Martin Paul Eve*, May 15, 2007, <https://doi.org/10.59348/yyyrg-ad033>.



Admittedly of limited use, here is a JavaScript function I wrote to detect the presence of httpOnly cookies. In Firefox the function will overwrite the real value of the cookie, so before using this function it is vital to try and read the cookie normally! Here is the script embedded in a test PHP page.

```
<?php

header('Cache-Control: no-cache');

header('Pragma: no-cache');

header("Set-Cookie: hidden=value; httpOnly");

?>

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

<html>

<head>

<title>HTTPOnly Cookie Test</title>

<meta http-equiv="Content-Type" content="text/html; charset=iso-8859-1"/>

<script type="text/javascript">

function testcookie(cookieName) {

document.cookie = cookieName + '=new_value; expires=Thu, 31 May 2007 20:47:11 UTC;
path=/';

if(document.cookie.indexOf(cookieName + '=') == -1) {

document.getElementById('displayer').innerHTML = 'Found a hidden (httpOnly) cookie
called "hidden"';

} else {

document.getElementById('displayer').innerHTML = 'Didn
<p>This works because when setting a cookie under Internet Explorer (which supports
httpOnly) with the same name as an httpOnly cookie the set operation fails and
therefore a simple comparison of the cookie state after the set reveals this, which can
be assumed to be an httpOnly cookie. Obviously this requires the attacker to be able to
guess the name of the httpOnly cookie in advance but may actually be of most use (at
present) as a browser detection agent.</p>
t find a hidden (httpOnly) cookie called "hidden"';

}

}
```

```
</script>

</head>

<body onload="javascript:testcookie('hidden')">

<span id="displayer" />

</body>

</html>
```

This works because when setting a cookie under Internet Explorer (which supports httpOnly) with the same name as an httpOnly cookie the set operation fails and therefore a simple comparison of the cookie state after the set reveals this, which can be assumed to be an httpOnly cookie. Obviously this requires the attacker to be able to guess the name of the httpOnly cookie in advance but may actually be of most use (at present) as a browser detection agent.